MITRE-RAG

İlk 7 haftanın araştırma ve teknik çıktıları

Bernanur Kalkan / Ankara Üniversitesi - Bilgisayar Mühendisliği

5 Kasım 2026

Kapsam: danışmanın onayladığı 14 haftalık planın 1-7. haftaları.

697 aktif ATT&CK kaydı, 1.993 metin parçası ve 384 boyutlu embedding indeksi hazır. Dört gerçek sorgu demosu ve 9 otomatik test başarıyla çalıştı.

Bu rapor bir ilerleme teslimidir. Dört demo, bağımsız etiketli test kümesi üzerinde yapılmış genel başarı değerlendirmesi değildir.

Kod ve kanıtlar: https://github.com/bernakalkann/mitre_rag_final

Hafta 1 - ATT&CK kavramları ve proje tanımı

Amaç

Kullanıcının yazdığı siber güvenlik olayı açıklamasından ilgili olabilecek MITRE ATT&CK Enterprise tekniklerini kaynaklarıyla getirmek. Sonraki aşamada yerel dil modeliyle kısa açıklama oluşturulacak ve anlamsal/hibrit erişim aynı senaryolarda karşılaştırılacak. Uygulama karar desteği sağlar; olayın gerçekten saldırı olduğunu otomatik doğrulamaz.

Kavramlar

Kavram	Anlamı	Örnek
Taktik	Davranışın amacı	Execution
Teknik	Amaca ulaşmak için kullanılan yöntem	T1059 - Command and Scripting Interpreter
Alt teknik	Tekniğin daha belirli bir biçimi	T1059.001 - PowerShell
Prosedür	Bir aktörün tekniği somut uygulama biçimi	Bir betiğin PowerShell üzerinden yürütülmesi

Bir teknik birden fazla taktikle ilişkili olabilir. Teknik adı, saldırganın niyetini tek başına kanıtlamaz. Örneğin PowerShell meşru yönetimde de kullanılır.

Örnek eşleşme incelemesi

“Saldırgan Windows üzerinde PowerShell ile kötü amaçlı bir betik çalıştırdı” girdisinde gözlenen davranış komut/betik yürütmedir. T1059.001 bu davranış için incelenecek adaydır: https://attack.mitre.org/techniques/T1059/001/ Bu örnek elle kurulmuş açıklayıcı bir senaryodur; çalıştırılmış model çıktısı değildir.

Araştırma sorusu

MITRE ATT&CK tekniklerini bulmada anlamsal arama ile anahtar kelime ve anlamsal aramayı birleştiren hibrit yaklaşımın doğruluk ve yanıt süresi nasıl farklılaşır? İleride Recall@K, MRR ve süre ölçümleri kullanılacaktır.

Kapsam: Enterprise ATT&CK, kısa doğal dil olayı, kaynaklı aday teknikler. Gerçek zamanlı SIEM, model eğitimi, gerçek sistemlere saldırı ve üretim ortamı kurulumu kapsam dışındadır. Kaynak: https://attack.mitre.org/

Hafta 2 - Kısa literatür özeti

RAG ve dil modeli

Lewis vd. (2020), dil modeliyle dış bilgi erişimini birlikte ele alır. Bu projede ATT&CK kayıtları dış bilgi kaynağı olacaktır. İlk 7 haftada yalnız erişim bileşeni hazırlanır; metin üretimi tamamlanmış sayılmaz. Kaynağa bağlı üretim, yanıtın doğru olacağını tek başına garanti etmez.

Kaynak: Lewis vd., *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks*, NeurIPS 2020. https://arxiv.org/abs/2005.11401

Embedding ve anlamsal arama

Reimers ve Gurevych (2019), cümleleri karşılaştırılabilir vektörlere dönüştüren Sentence-BERT yaklaşımını açıklar. Projedeki kullanım: teknik açıklamaları ve olay açıklamasını aynı embedding uzayında temsil edip kosinüs benzerliğiyle sıralamak. Teknik kimliği veya tam anahtar kelime geçmese de anlamsal yakınlık aday bulmaya yardımcı olabilir; gerçek başarı ayrıca ölçülmelidir.

Kaynak: *Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks*. EMNLP-IJCNLP 2019. DOI: 10.18653/v1/D19-1410. https://aclanthology.org/D19-1410/

Uygulama kaynağı:
https://sbert.net/examples/sentence_transformer/applications/semantic-search/README.html

BM25 ve hibrit yaklaşım

BM25, sorgudaki terimlerin belgeyle eşleşmesine dayanan bir erişim yaklaşımıdır. Teknik adları, araç adları ve komutların açık geçtiği sorgularda ayrı bir karşılaştırma sunacaktır. Hibrit sistemde anahtar kelime ve vektör sonuçları birleştirilecek; bunun daha başarılı olduğu deneyden önce varsayılmayacaktır. BM25 uygulaması 9., hibrit uygulama 10. haftadır.

Temel bilgi erişim kaynağı: Manning, Raghavan ve Schütze (2008), *Introduction to Information Retrieval*. https://nlp.stanford.edu/IR-book/

Veri ve model kaynakları

- MITRE ATT&CK veri araçları: https://attack.mitre.org/resources/attack-data-and-tools/

- Resmî STIX 2.1 deposu: https://github.com/mitre-attack/attack-stix-data

- Seçilen çok dilli model kartı:
https://huggingface.co/sentence-transformers/paraphrase-multilingual-MiniLM-L12-v2

Bu not, yukarıdaki temel kaynakların projeyle ilişkisini özetler; sistematik literatür taraması veya bütün makalelerin ayrıntılı incelemesi iddiası taşımaz. Türkçe/İngilizce örnek demolar çalıştırıldı; genel eşleştirme başarısı bağımsız bir etiketli veri kümesinde henüz ölçülmemiştir.

Hafta 3 - Gereksinimler ve teknik durum

Kabul edilecek davranışlar

Kod	Gereksinim	Kontrol
G1	Enterprise STIX dosyasından teknik ve alt teknik ayrıştırma	Gerçek veri raporu
G2	Revoked/deprecated kayıtları aramadan çıkarma	Filtre testi ve kayıt sayıları
G3	Kimlik, açıklama, üst teknik, taktik, platform ve kaynak saklama	Örnek kayıt incelemesi
G4	Teknik metinlerinden gerçek model embedding'i üretme	İndeks manifesti doğrulandı
G5	Olay açıklamasını aynı modelle kodlayıp ilk K benzersiz tekniği getirme	Dört gerçek demo kaydedildi
G6	Teknik kodu, ad, benzerlik ve resmî kaynak gösterme	Gerçek sorgu çıktılarında mevcut
G7	Veri özeti ve model revizyonuyla tekrar çalıştırılabilirlik	Manifestler ve README
G8	Geçersiz veri, boş/çok uzun sorgu ve bozuk indeks için açık hata	Kod kontrolleri ve temel sözleşme testleri

Staj kodunun incelemesi

Referans repo: https://github.com/bernakalkann/mitre-rag İncelenen yerel HEAD: f9f0004ec84a3dffed981a9cb75c500671789dd4.

- app/parsers/stix_parser.py: çok sayıda STIX nesne türü ve ilişki çözümleme.

- app/embeddings/ollama_embedder.py: Ollama üzerinden embedding isteği.

- scripts/download_attack_data.py: kaynak, indirme tarihi ve hash manifesti.

- app/retrieval/, app/llm/, API ve arayüz: ilk 7 haftadan geniş kapsam.

- README çalışır sistem ve değerlendirmeler bildiriyor; bu incelemede o

iddialar tekrar çalıştırılıp doğrulanmadı.

Karar: Yapıyı tümüyle kopyalamak yerine, planın ilk 7 haftasına uygun küçük ve bağımsız bir Python paketi yazıldı. Kaynak verisi özgün manifestiyle yeniden kullanıldı. Staj projesinin .env, eski değerlendirme sonuçları ve özel belgeleri taşınmadı. Stajın kapsamı bitirme projesine zorunluluk oluşturmaz.

İleride değerlendirilecek gereksinimler

Yerel LLM, BM25, hibrit arama ve Streamlit genel proje hedefidir; bu teslimin çalışır bileşenleri olarak sunulmaz. Karşılaştırmada alt tekniklerin üst tekniğe dönüşümü ve tekilleştirme politikası deney öncesinde açıkça tanımlanacaktır.

Hafta 4 - Teknoloji ve mimari

Kararlar

Bileşen	Seçim	Gerekçe
Çalışma ortamı	Python 3.12	Staj ortamından bağımsız sanal ortam
Veri	ATT&CK Enterprise STIX/JSON	Planın resmî bilgi kaynağı
Embedding	Sentence Transformers	Plandaki metin gösterimi yaklaşımı
İlk model	paraphrase-multilingual-MiniLM-L12-v2	İki dilde demo çalıştı; genel başarı ölçümü sonraki aşama
Arama	NumPy, normalize vektörlerin iç çarpımı	Küçük derlemde açık ve denetlenebilir kosinüs sıralaması
Saklama	JSON/JSONL ve NPY	Ayrı veritabanı servisi gerektirmeyen ilk sürüm
Çalıştırma	Komut satırı	7. hafta için yeterli; arayüz 11. haftada
Sonraki aşama	Ollama ve Streamlit	Şimdilik kuruluma zorunlu eklenmez

Model kartı modelin 384 boyutlu cümle/paragraf temsili ürettiğini belirtir. Gerçek indeks boyutu çalışma sırasında doğrulanıp manifestte kaydedilecektir. Kaynak: https://huggingface.co/sentence-transformers/paraphrase-multilingual-MiniLM-L12-v2

Veri akışı

Teknik açıklamaları modelin token sınırına göre örtüşen parçalara bölünür. Her parça teknik kimliğine bağlıdır. Aynı tekniğin en yüksek benzerlikli parçası o tekniği temsil eder. Sonuçlar benzersiz teknik kimlikleriyle sunulur. Bu sürümde alt teknikler ayrı adaydır; üst tekniklere toplama yapılmaz.

Model yükleme süresi sorgu+arama ölçümüne dahil değildir ve çıktıda belirtilir. Bu demo süreleri, 13. haftadaki kontrollü yöntem karşılaştırmasının yerine geçmez.

Hafta 5 - ATT&CK veri modeli

STIX attack-pattern nesneleri ayrıştırılır. mitre-attack dış referansındaki T kodu esas alınır. Aktif Enterprise kayıtları aranır; revoked veya x_mitre_deprecated işaretli kayıtlar dışarıda bırakılır.

Alan	Tür	Amaç
stix_id	string	Özgün STIX nesne kimliği
attack_id	string	T1059 veya T1059.001 gibi teknik kodu
name	string	Teknik adı
description_raw	string	Özgün açıklamanın korunması
description	string	Arama için temizlenmiş açıklama
is_subtechnique	boolean	Alt teknik göstergesi
parent_attack_id	string/null	Alt tekniğin üst tekniği
tactics	string listesi	ATT&CK kill-chain aşamaları
platforms	string listesi	İlgili platformlar
source_url	string	Resmî teknik sayfası
modified	string/null	STIX kaydının değişiklik zamanı

Üst teknik ilişkisi aktif subtechnique-of ilişkisinden alınır. İlişki yoksa ATT&CK kimliğinin noktadan önceki bölümü kullanılır. Taktikler tek bir sınıf etiketi olarak zorlanmaz; bir teknik birden fazla taktik içerebilir.

Temizleme: (Citation: ...) işaretleri kaldırılır; Markdown bağlantılarının görünen metni korunur; HTML etiketleri ve fazla boşluklar temizlenir. Ham açıklama, izlenebilirlik için ayrı alanda tutulur.

Gerçek veriden alınmış örnekler: sample_records.json. Teknik/alt teknik sayıları: data_report.json.

Kayıt nesnesinin modified alanı, ATT&CK sürümüyle aynı şey değildir. Derlem sürümü ve SHA-256 özeti veri manifestinde; model revizyonu indeks manifestinde tutulur. Boş ya da yinelenen kimlikli derlem sessizce kabul edilmez.

Kaynak: https://github.com/mitre-attack/attack-stix-data

Hafta 6 - Ortam ve veri hazırlığı

Gerçekten çalıştırılan adım

Yeni ayrıştırıcı, yereldeki resmî ATT&CK STIX kopyasıyla çalıştırıldı. Dosyanın SHA-256 özeti önceki indirme manifestiyle eşleştirildi. Derlemdeki koleksiyon sürümü **19.1**. Bu, kullanılan anlık görüntüdür; bugünün en yeni ATT&CK sürümü olduğu iddia edilmez.

- İncelenen attack-pattern: 858.

- Revoked/deprecated nedeniyle dışlanan: 161.

- Aktif ve işlenen kayıt: 697.

- Üst teknik: 222; alt teknik: 475.

- Gerçek veri raporu: data_report.json.

Bu sayılar kullanılan dosya içindir; güncel web sayfasındaki sayılarla aynı olması gerekmez. Önce mevcut kopyanın özgün indirme manifesti korundu. Erişim açılınca sürümlü resmî dosya ayrıca yeniden indirildi ve SHA-256'sının aynı olduğu doğrulandı: download_verification.json.

Ortam

Veri hazırlığı, 9 sözleşme testi ve gerçek embedding/arama, mevcut Python 3.12.13 ortamında çalıştırıldı. Yeni proje için temiz ortam kurulum adımları README'dedir. Ayrı bir temiz sanal ortam kurulumu ayrıca doğrulanmadı.

İlk denemede ağ kısıtı vardı. Erişim açıldıktan sonra seçilen Sentence Transformer modeli indirildi. Gerçek indeks oluşturuldu ve dört sorgu çalıştırıldı. Bu aşama Ollama gerektirmez. Model ve paket sürümleri evidence/index_manifest.json dosyasındadır. Model önbelleği HF_HOME ile proje içindeki, Git'in dışladığı data/model_cache klasörüne yönlendirildi.

Yeniden çalıştırma

```
python -m mitre_final download
python -m mitre_final prepare
python -m unittest discover -s tests -v
```

İndirme adımı sürüm dosyasını ve beklenen SHA-256'yı kontrol eder. Kaynak değişirse özet körlemesine güncellenmez; fark incelenir. Ham veri Git'e eklenmez.

Hafta 7 - Anlamsal arama modülü

Uygulama

mitre_final/search.py, Sentence Transformer modelini yükleme, token sınırına uygun parçalama, normalize embedding üretme, indeks kaydetme ve sorgu sıralama işlemlerini içerir. Model CPU üzerinde çalıştırılır; aynı modelin kaydedilmiş revizyonu sorgu sırasında da kullanılır. İndeks dosyalarının SHA-256 özetleri yüklemede doğrulanır.

Her teknik için birden çok metin parçası olabilir. Kosinüs sıralamasından sonra aynı teknik kimliği tekrarlanmaz; en iyi parçası sonuçta kanıt metni olarak sunulur. Üst ve alt teknik bu sürümde ayrı kimliklerdir. Sonuçlar adaydır; LLM gerekçelendirmesi ve kesin saldırı tespiti yapılmaz.

Doğrulama durumu

Gerçek modelle indeks ve dört sorgu demosu tamamlandı. 697 kayıt 1.993 parçaya ayrıldı ve 384 boyutlu vektörlere dönüştürüldü. Token sınırı 128; kaydedilen parçaların hiçbiri sınırı aşmıyor. İndeks, demo çıktıları ve token kontrolü evidence/ altındadır.

9 otomatik testin içinde veri filtreleme, kaynak özeti, yinelenen teknik, kosinüs sıralama, parçaları tekilleştirme ve geçersiz vektör kontrolleri vardır. Bu testlerdeki sentetik vektörler, gerçek embedding çalışması yerine geçmez.

Gerçek demo sonuçları

Olay	İncelenen aday	Gözlenen sıra
PowerShell ile betik yürütme, İngilizce	T1059.001	1
PowerShell ile betik yürütme, Türkçe	T1059.001	1
Yeniden başlatma sonrası zamanlanmış görev	T1053.005	2; üst teknik T1053 ilk sırada
LSASS belleğinden kimlik bilgisi	T1003.001	1

Bu dört örnek elle hazırlanmış gösterimlerdir. Bağımsız benchmark değildir; buradan genel başarı yüzdesi, Recall@K veya MRR sonucu çıkarılmamıştır.

Model revizyonu, paket sürümleri ve boyutlar evidence/index_manifest.json; gerçek sonuçlar semantic_demo_en.json ve semantic_demo_tr.json içindedir. examples/demo_queries.json dosyasındaki inspect_candidate, elle seçilmiş incelenecek adaydır. Gerçek model sırası ayrı demo çıktısından okunur.

Sınırlılıklar

Çok dilli model seçimi Türkçe başarısı garantilemez. Uzun sorgular reddedilir; kısa olay açıklamalarıyla başlanır. Benzerlik skoru güven olasılığı değildir. Doğruluk, Recall@K ve MRR karşılaştırması 12-13. haftada hazırlanacak bağımsız etiketli örnekler üzerinde yapılacaktır.